Glassbox — findings, 16 September 2026

One Cowork session, two releases, two real-transcript runs, and what they found. Written by Claude for Aldo Hushi to pick up on the 17th.

The day started as "PDF the product list and go wild again" and ended with Glassbox at 0.9.0: two of the products on that list are built, tested and sitting in `sesh\glassbox` waiting for the GitHub upload. Both were run on real transcripts before being called done, and both runs found things — one of them about the tool, one of them about me.

1. What was built

0.8.0 — Fence: secrets that reached a transcript **built · tested · delivered**

`glassbox fence [ID|FILE|DIR] [--since] [--project] [--format text|md|json] [--out] [--fail-on error|warn|info] [--shred]`. Scans Claude Code transcripts for credentials by format (AWS, GitHub, Anthropic, OpenAI, Slack, Stripe, Google, npm, SendGrid, private-key blocks, database URLs with passwords — *error*), secrets by context (`password=`, `api_key:`, `Bearer`, basic-auth URLs, JWTs — *warn*) and credential-file reads (`.env`, `.npmrc`, `.netrc`, `id_rsa`, `*.pem`, `secrets.json` — *info*). Every row is a masked preview and an 8-hex SHA-256 fingerprint, never the value; the same key can be recognised across sessions without the report carrying it. `--shred` overwrites each value in place with `[FENCED:rule:fingerprint]`: no backup, every rewritten line re-parsed before anything is written, atomic rename, CRLF preserved. A shredded transcript still opens and checks.

Engineering: DESIGN.md §14, nine tests written before the code, 111 total, e2e and audit green. Docs: FENCE.md, IT.md §6b, PILOT.md day-0 sweep, README, CHANGELOG.

0.9.0 — Adhere: "is my CLAUDE.md doing anything?" **built · tested · delivered**

`glassbox adhere [--project DIR] [--claude-md FILE] [--since] [--format] [--out] [--redact] [--fail-under N]`. Reads the project's instruction files (`CLAUDE.md`, `.claude/CLAUDE.md`, `CLAUDE.local.md`, `~/.claude/CLAUDE.md`), turns each line into a rule, finds every session of that project, and judges each rule per occasion with evidence (session, turn prompt, command or path). Nine shapes are checkable mechanically: run X before commit/push, run X after changes, use A not B, never run, never touch, ask before, read before edit, commit message format, no new docs. Everything else is listed as *not checkable yet* with its line number, so the report never claims more than it measured. Headline: *N rules · K checkable · sessions · obeyed X of Y occasions (Z%)*.

Engineering: DESIGN.md §15, ten tests before the code, 121 total, e2e and audit green. Docs: ADHERE.md, IT.md §6c, README, CHANGELOG.

Also produced

`docs/Glassbox-next-products.pdf` (+ .html) — the seven-product list with status and sizing. `docs/RELEASE-0.8.0.md` and `docs/RELEASE-0.9.0.md` — the 0.9.0 note carries a single upload order covering both releases, since 0.8.0 was never pushed on its own.

2. What the real runs found

Fence, run on the session that built it

1.2 MB, one transcript. 50 findings, 19 distinct secrets — every one of them a planted test value that had passed through tool inputs and outputs while the tests were being written. `--shred` on a copy rewrote 96 occurrences; all 221 lines still parsed and `glassbox check` gave the same result. On the real fixture transcript (`test/fixtures/real-main.jsonl`): nothing found, which is the correct answer for that file. The point for the launch post: the tool's own build session is proof that a transcript collects everything the agent touches, including secrets it was only shown in passing.

Adhere, run on the session that built it

Against a CLAUDE.md written for the test with the rules Glassbox would plausibly have, the score was **22%** — 12 of 54 occasions.

rule	shape	occasions	obeyed	verdict
Use rg rather than grep.	prefer-tool	38	0	ignored
Never create markdown files unless asked.	no-new-docs	2	0	ignored
Use conventional commits.	commit-format	1	0	ignored
Ask before committing.	ask-before	1	0	ignored
Never edit files in dist/ by hand.	never-touch	8	8	obeyed
Always run npm test before committing.	run-before	1	1	obeyed
Run the tests after making changes.	run-after	1	1	obeyed
Never force push.	never-run	1	1	obeyed
Read a file before editing it.	read-before-edit	1	1	obeyed
Keep the CLI dependency-free. / Prefer small, single-purpose modules.	—	not checkable yet		

The reading: the rules that were obeyed are the ones that cost nothing to obey (don't touch dist, don't force push). The ones ignored are habits — grep over rg 38 times in one session — and the ones where the instruction was never in the prompt at the moment of the action (the one commit was requested by a Stop hook, not by you, and its message was `v0.8.0: glassbox fence — …`, not `feat:`). That is the honest shape of the answer to "is my CLAUDE.md doing anything?": *the cheap rules, yes; the habit-changing rules, much less; and you can now see which is which.*

Three bugs the first run found in the tool itself

The first pass of the same run scored 19% and was wrong in both directions. A `git push --force` inside a document being written with a heredoc was counted as a force push (3 breaches). Commits inside `node -e "…"` test strings were counted as commits (5 instead of 1). The one real commit was missed entirely because it read `git -c user.name=… commit`. All three are fixed by judging commands on their *shell surface* — heredoc bodies and inline programs

are content, segments split on `&&` `|` `;` and newlines, `git`'s leading options looked through — and all three are now tests. This is exactly what the "run it on a real transcript before calling it done" rule is for.

3. State of the repo and the site

where	version	note
`sesh\glassbox` (your PC)	0.9.0	all files written; local matched GitHub byte-for-byte before the day's changes
Cloud clone, branch `v0.8.0-fence`	0.9.0	two commits, c9b4747 (0.8.0) and c6e98f5 (0.9.0); push refused as always (repo not in the session's authorised set)
GitHub `origin/main`	0.7.1	nothing from today is on it yet
npm `glassbox-trace`	0.7.1	publish after the push (Actions → publish → Run workflow)
blueprintau.com/glassbox/	0.7.1	no "New in 0.8/0.9" yet; app/ viewer unchanged apart from version string
Claude artifact	0.7.1 (v13)	viewer has no fence/adhere UI, so not urgent
IT / pilot PDFs	0.7.1 renderings	the .md files are current and carry the new sections; regenerate when next needed
Still unpushed from before	—	test/action.test.mjs, docs/CI.md, the Node 24 workflow files (yours to upload)

4. To pick up on the 17th

In the order I'd take them, but they are independent:

#	what	who	size
1	**Run `adhere` on your own projects** — `node bin\glassbox.mjs adhere --project <folder with a CLAUDE.md>` from `sesh\glassbox`, and `--home` at the copied transcripts in `sesh\projects` if the live ones are elsewhere. The 22% is a good story; your number is the post. Send me the output (or `--redact` it) and I'll read it for parser misses the way I read my own.	you	10 min
2	**Push 0.8.0 + 0.9.0 to GitHub and publish** — upload order in docs/RELEASE-0.9.0.md (one list for both). Either you upload, or I do it from your Chrome via the web upload page as before. Then Actions → publish → Run workflow. No GitHub Release.	either	30 min
3	**LinkedIn Post 4 is due Thu 17 Sep** per CAMPAIGN.md, and the X thread slot is the same day. Fence's "the session that built it had 19 secrets in it" and Adhere's "22%" are both stronger than whatever Post 4 was going to be; pick one, or run the two on consecutive days.	you decide	—
4	**Site: "New in 0.9"** — fence + adhere block, `v0.9.0` Get-it line, app/ viewer swap. Same cPanel zip route as before once you've logged in.	me, after you log in	30 min

#	what	who	size
5	**Startup tax** — the next product on the list: the cold-open cost per session and per fleet, one rule in `check` plus a table in `collect`. One day.	me	1 day
6	**Adhere, second pass** — after real-project runs: more rule phrasings, skill-fired checks, and the `ask-before` "standing instruction" case (a commit asked for in an earlier turn). Only worth doing against real CLAUDE.md files.	me, after #1	1–2 days

5. One thing worth keeping

Both tools were only right after they were run on a real transcript. The tests passed before that; the real run is what found the heredoc, the inline program and the `git -c` case. "Ship nothing that hasn't been run on the session that built it" is a rule now — and, yes, it is checkable.